tfscan: Terraform Misconfiguration Scanner

Static AWS Security Analysis with a Measured Checkov Comparison

Author: Raj Chhapariya | **Date:** October 2026 | **Target:** AWS Static IaC Analysis

1. Question and method

Can a small static scanner for 12 AWS rules, which returns UNKNOWN instead of guessing when a value cannot be resolved, match Checkov on a hand-labelled set? Ground-truth labels were established by manual code inspection prior to running either scanner to eliminate label contamination from scanner outputs. Three subsequent adjustments to fixtures and labels are documented in `docs/LABEL_CHANGES.md`. The evaluation sets comprise 102 fixture resources developed for this project, and 33 scored items on TerraGoat (AWS folder, pinned commit `729f8da`). Each fixture is scanned in its own directory to prevent cross-file state leakage. Results are keyed by full path and resource address. A mapped Checkov check that did not run on an item is counted as a miss, not as a pass.

2. Caveats and Evaluation Baselines

- The fixtures were written together with the scanner. High scores on them are weak evidence. TerraGoat is the independent set and is small (33 scored items).
- TerraGoat was built by Bridgecrew, the company behind Checkov, creating an inherent benchmark bias toward Checkov.
- AWS has applied SSE-S3 default encryption to all new buckets since January 2023; therefore, rule S3-03 has severity LOW and verifies explicit cryptographic choice in code (such as KMS CMK or AES256) rather than physical lack of encryption. Checkov check CKV_AWS_19 passes buckets without an encryption block, whereas tfscan S3-03 requires an explicit declaration. The headline benchmark row leaves S3-03 out.
- SEC-01 maps only to CKV_AWS_41 (provider blocks). Checkov's separate secrets scanner was not run, which lowers Checkov's SEC-01 recall.
- Each timing measurement is recorded from a single run on Windows 11.

3. Results

Rule	Items	tfscan P	tfscan R	tfscan F1	tfscan UNK	Checkov P	Checkov R	Checkov F1	Checkov No-Check
CT-01	6	100.0%	100.0%	1.000	25.0%	100.0%	100.0%	1.000	0
EBS-01	7	100.0%	100.0%	1.000	22.2%	100.0%	100.0%	1.000	2
IAM-01	8	100.0%	100.0%	1.000	20.0%	100.0%	100.0%	1.000	0
KMS-01	7	100.0%	100.0%	1.000	22.2%	100.0%	100.0%	1.000	2
RDS-01	7	100.0%	100.0%	1.000	22.2%	100.0%	100.0%	1.000	2
RDS-02	7	100.0%	100.0%	1.000	22.2%	100.0%	100.0%	1.000	2
S3-01	12	100.0%	100.0%	1.000	14.3%	90.0%	100.0%	0.947	2
S3-02	12	100.0%	100.0%	1.000	14.3%	100.0%	100.0%	1.000	2
S3-03	13	100.0%	100.0%	1.000	13.3%	n/a	0.0%	n/a	2
SEC-01	9	100.0%	100.0%	1.000	18.2%	100.0%	40.0%	0.571	6
SG-01	9	100.0%	100.0%	1.000	18.2%	100.0%	100.0%	1.000	0
SG-02	9	100.0%	100.0%	1.000	18.2%	100.0%	100.0%	1.000	0
All 12	106	100.0%	100.0%	1.000	18.5%	97.7%	79.6%	0.878	20
All but S3-03	93	100.0%	100.0%	1.000	19.1%	97.7%	93.5%	0.956	18
Fixtures	73	100.0%	100.0%	1.000	24.7%	96.9%	86.1%	0.912	19
TerraGoat	33	100.0%	100.0%	1.000	0.0%	100.0%	66.7%	0.800	1

Table 1: Precision, recall, F1 against hand labels. UNKNOWN-labelled items are excluded from P and R.

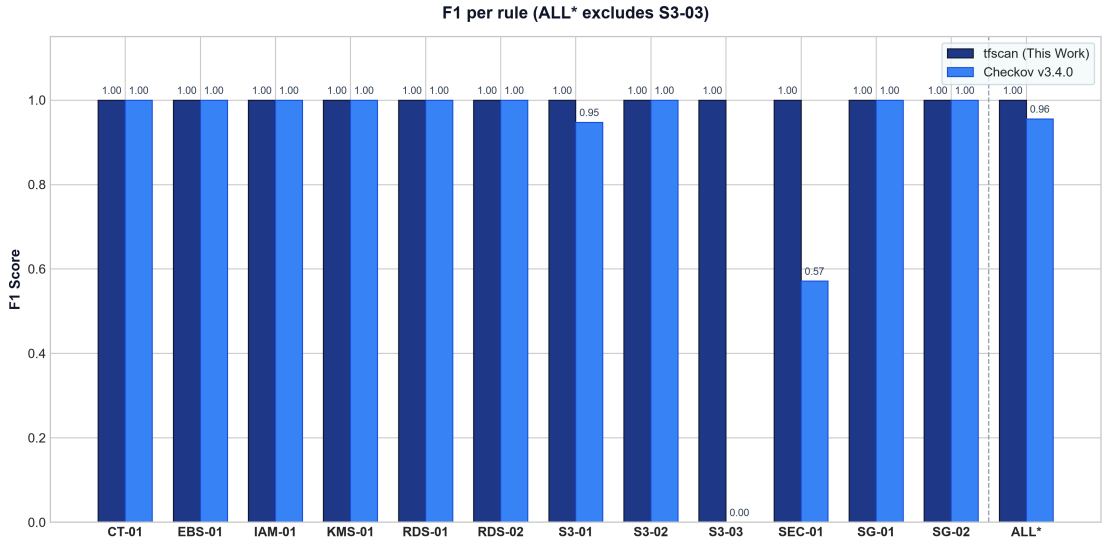


Figure 1: F1 score comparison per rule across all 12 evaluated checks (ALL excludes S3-03).*

On the items with a definite label, tfscan scored precision 100.0% and recall 100.0%; Checkov scored 97.7% and 79.6% (all 12 rules). Without S3-03, Checkov recall is 93.5%. On TerraGoat alone tfscan scored 100.0% recall and Checkov 66.7%. Of 24 items labelled unknowable, tfscan answered UNKNOWN on 24; Checkov gave a definite FAIL or PASS on 8.

Timing (wall clock, includes process start-up): fixtures, tfscan CLI 272 ms against Checkov 35250 ms; TerraGoat AWS, 264 ms against 27326 ms. Much of the gap is start-up cost, so it should not be read as a per-resource speed ratio.

4. Disagreements

21 labelled items got different verdicts. tfscan matched the label on 13, Checkov on 0, and 8 were unknowable items. Per-item notes are in `docs/disagreement_notes.csv` and the README.

Item	Rule	Label	tfscan	Checkov	Right
Fi: case3_v4_pab_linked_by_name.tf	S3-01	PASS	PASS	FAIL	tfscan
Fi: case1_v3_no_sse.tf	S3-03	FAIL	FAIL	PASS	tfscan
Fi: case2_v4_no_sse.tf	S3-03	FAIL	FAIL	PASS	tfscan
Fi: case3_v4_unrelated_resource.tf	S3-03	FAIL	FAIL	PASS	tfscan
Fi: case1_cidr_variable.tf	SG-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case2_port_variable.tf	SG-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case1_cidr_var.tf	SG-02	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case2_rule_remote_state.tf	SG-02	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case1_unresolved_multi_region.tf	CT-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case2_unresolved_validation.tf	CT-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case1_policy_variable.tf	IAM-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case2_template_file.tf	IAM-01	UNKNOWN	UNKNOWN	PASS	n/a (unknowable)
Fi: case2_db_literal_password.tf	SEC-01	FAIL	FAIL	NO_CHECK	tfscan
Fi: case3_resolved_default_password.tf	SEC-01	FAIL	FAIL	NO_CHECK	tfscan
Fi: case2_var_no_default.tf	SEC-01	PASS	PASS	NO_CHECK	tfscan
Te: s3.tf aws_s3_bucket.data	S3-03	FAIL	FAIL	PASS	tfscan
Te: s3.tf aws_s3_bucket.financials	S3-03	FAIL	FAIL	PASS	tfscan
Te: s3.tf aws_s3_bucket.operations	S3-03	FAIL	FAIL	PASS	tfscan
Te: s3.tf aws_s3_bucket.data_science	S3-03	FAIL	FAIL	PASS	tfscan
Te: ec2.tf aws_s3_bucket.flowbucket	S3-03	FAIL	FAIL	PASS	tfscan
Te: db-app.tf aws_db_instance.default	SEC-01	FAIL	FAIL	NO_CHECK	tfscan

Table 2: All disagreements. “Right” is blank-equivalent n/a for unknowable items.

5. Limits and what was fixed along the way

Evaluation exposed two scanner weaknesses, both found by checking disagreements against the code. The security-group rules asked for the CIDR before the port, so a rule on port 3306 with an unresolvable CIDR came back UNKNOWN; the port is now checked first. S3-03 returns UNKNOWN when an explicit encryption block has a KMS key given as a reference, which the labels treat as a pass; this is not fixed and is the one TerraGoat item where tfscan answered UNKNOWN against a PASS label. Static analysis of `.tf` files cannot see values set outside the code, which is why UNKNOWN exists.

6. Reproduce

`pip install -e .[dev]`, `bash scripts/fetch_terragoat.sh`, `python eval/run_scans.py`, `python -m eval.score`, `python -m eval.disagreements`, `python -m eval.plot_figure`, `python -m eval.generate_artifacts`, `python report/generate_report.py`. Environment: `results/ENVIRONMENT.md`.